



수동 조치 가이드라인 ubuntu

💡 본 문서는 자동화 스크립트로 조치가 불가능하거나, 관리자의 판단이 필요한 항목들에 대한 대응 지침을 담고 있습니다. 각 항목의 번호를 확인하여 수동으로 조치하는 것을 권장합니다.

⚠️ [수동 점검 및 조치 항목]

해당 항목들은 서비스 영향도 평가가 필요하거나, 시스템 환경에 따라 개별 설정이 필요한 항목입니다.

- 1, 2, 7, 9, 23, 25, 28, 30, 33, 40, 45, 47, 49, 50, 51, 56, 61, 64, 66

✅ 조치 후 공통 절차

1. 설정 변경 전 반드시 해당 설정 파일의 **백업본**을 생성하십시오.
2. 설정 적용 후 관련 서비스를 **재시작**하고 정상 작동 여부를 확인하십시오.



[U-01] root 계정 원격 접속 제한 가이드라인

[Rocky Linux 9 / 10] 조치 방법

Step 1) SSH (Secure Shell) 설정 수정

1. 설정 파일을 엽니다.

```
sudo vi /etc/ssh/sshd_config
```

2. `PermitRootLogin` 설정을 찾아 **no**로 수정합니다. (주석 `#` 이 있다면 제거)

```
PermitRootLogin no
```

3. 서비스를 재시작하여 적용합니다.

```
sudo systemctl restart sshd
```

Step 2) Telnet 설정 점검 (선택 사항)

- CentOS 8 이상은 `/etc/securetty` 파일이 존재하지 않으며 기본적으로 Telnet 서비스가 비활성화되어 있습니다. 만약 Telnet 서비스를 사용하거나, `/etc/securetty` 파일을

생성하여 사용 중이라면, 아래 절차를 따르십시오.

1. **/etc/pam.d/login** 설정: 파일 내에 아래 라인을 추가합니다.

```
sudo vi /etc/pam.d/login  
auth required /lib/security/pam_securetty.so
```

2. **/etc/securetty** 설정: 해당 파일이 존재할 경우, 내부의 `pts/x` 설정(원격 터미널)을 모두 주석 처리하거나 삭제합니다.

```
sudo vi /etc/securetty  
  
#pts/0 , #pts/1 , #pts/2 ...
```

※ 주의: Rocky 9은 이 파일이 없는 것이 기본이며, 파일이 없으면 원격 root 접속이 자동으로 차단되므로 억지로 만들지 않습니다.

[Ubuntu 24.04] 조치 방법

Ubuntu 24.04는 데비안 계열의 최신 보안 정책을 따르며, SSH 설정 방식은 유사하나 PAM 모듈 구조가 다를 수 있습니다.

Step 1) SSH (Secure Shell) 설정 수정

1. 설정 파일을 편집합니다.

```
sudo nano /etc/ssh/sshd_config
```

2. `PermitRootLogin` 옵션을 **no**로 설정합니다.

```
PermitRootLogin no
```

(참고: Ubuntu는 기본적으로 `prohibit-password` 인 경우가 많으나, 보안 가이드라인 준수를 위해 확실히 `no` 로 변경하는 것이 좋습니다.)

3. 서비스를 재시작합니다.

```
sudo systemctl restart ssh
```

Step 2) Telnet 설정 점검 (선택 사항)

1. **/etc/pam.d/login** 설정: 파일 상단에 아래 라인을 추가하여 원격 접속 시 보안 터미널 체크를 강제합니다.

```
auth required pam_securetty.so
```

(참고: Ubuntu 24.04에서는 경로 없이 모듈명만 입력해도 무방합니다.)

2. **/etc/securetty** 설정: Ubuntu 24.04는 이 파일이 기본적으로 존재하지 않습니다. 만약 수동으로 생성하여 사용 중이라면, 파일 내 `pts/` 로 시작하는 모든 라인을 주석 처리하거나 삭제하십시오.

#pts/0 , #pts/1 , #pts/2 ...

중요: `/etc/securetty` 파일 내에 `pts/x` 설정이 존재하면 PAM 모듈 설정과 관계없이 root 접속을 허용하게 되므로 반드시 제거가 필요합니다.

[U-07] 불필요한 계정 제거

수동 조치가 필요한 이유

시스템 계정은 서버의 성격과 설치된 애플리케이션에 따라 그 용도가 매우 다양합니다. 자동화된 스크립트만으로는 특정 계정이 현재 운영 중인 서비스(예: 백업, 모니터링, 특정 웹 엔진 등)에 필수적인 계정인지, 아니면 퇴직자나 과거의 테스트용 계정인지 정확히 판별하기 어렵습니다.

만약 운영에 필수적인 시스템 계정을 단순히 '사용하지 않는 것 같다'는 이유로 자동 삭제할 경우, **연관된 서비스가 즉시 중단되거나 시스템 장애**가 발생할 수 있습니다. 반대로 관리되지 않는 유령 계정을 방치하면 공격자가 이를 탈취해 침투 경로로 악용하더라도 탐지가 매우 어렵습니다. 따라서 **관리자가 인사 기록 및 서비스 현황을 바탕으로 직접 계정의 유효성을 수동으로 검증하고 조치**해야 합니다.

조치 시 주의사항 (공통)

- 업무 영향도를 검토한 후 사용하지 않는 계정을 삭제합니다.
- `/etc/passwd` 파일에서 계정 앞에 `#`을 삽입하여도 주석으로 처리되지 않으므로 조치 시에는 반드시 계정을 제거하도록 권고합니다.
- 이때 사용하는 시스템 계정을 삭제하지 않도록 유의합니다.

[Rocky Linux 9 / 10] 조치 방법

Step 1) 시스템 계정 및 로그인 이력 확인

1. 전체 계정 리스트 확인:

```
cat /etc/passwd
```

2. 최근 로그인 기록 확인:

```
lastlog
```

Step 2) 불필요한 계정 삭제

1. 계정 삭제 (홈 디렉토리 포함하여 삭제):

```
userdel -r <사용자 이름>
```

[Ubuntu 24.04] 조치 방법

Step 1) 계정 현황 파악

1. 사용자 목록 확인:

```
cut -d: -f1 /etc/passwd
```

2. 로그인 정보 분석

```
lastlog
```

Step 2) 불필요한 계정 삭제

1. 계정 삭제 (홈 디렉토리 포함하여 삭제):

```
sudo deluser --remove-home <사용자 이름>
```

[U-09] 계정이 존재하지 않는 GID 금지 가이드라인

수동 조치가 필요한 이유

`/etc/group` 파일에 계정이 존재하지 않는 불필요한 그룹(GID)이 방치되어 있을 경우, 공격자가 시스템에 침투한 후 권한 상승을 위해 해당 GID를 악용할 수 있습니다. 예를 들어, 특정

그룹에만 허용된 파일 권한을 탈취하거나, 나중에 동일한 GID로 새로운 계정을 생성하여 이전 그룹의 권한을 그대로 물려받는 '권한 재사용' 공격의 빌미가 됩니다.

하지만 단순히 사용자가 없다고 해서 무작정 그룹을 삭제하면 안 됩니다. 특정 시스템 서비스나 애플리케이션이 **파일 실행 권한을 제어하기 위해 해당 그룹을 내부적으로 참조**하고 있을 수 있기 때문입니다. 만약 그룹을 삭제해버리면 해당 파일들의 그룹 소유권이 숫자로만 남게 되어(Orphaned files) 보안 관리가 불가능해지거나 서비스 장애가 발생할 수 있습니다. 따라서 **관리자가 실제 파일 소유 현황과 서비스 연관성을 수동으로 꼼꼼히 검토한 후 조치**해야 합니다.

! 조치 시 주의사항 (공통)

- 그룹을 삭제하기 전, 해당 그룹 권한으로 설정된 중요한 데이터 파일이나 실행 파일이 존재하는지 반드시 확인하십시오. 그룹 삭제 후 파일의 GID가 숫자로만 표시(Orphaned)될 수 있습니다.
- 현재 사용자가 없더라도 향후 특정 권한 할당을 위해 미리 생성해둔 그룹일 수 있으므로, 관리자와 충분히 검토한 후 삭제를 진행하십시오. OS 설치 시 기본적으로 생성되는 시스템 그룹(bin, sys, daemon 등)은 서비스 작동에 필수적이므로 제거 시 주의가 필요합니다.

1. [Rocky Linux 9 / 10] 조치 방법

Step 1) 불필요한 그룹 현황 점검

1. 전체 그룹 리스트 확인:Bash

```
cat /etc/group
```

2. 계정이 할당되지 않은 그룹 확인:

`/etc/passwd` 파일의 GID 필드와 비교하여, 어떤 사용자도 기본 그룹으로 사용하지 않고 소속된 멤버도 없는 그룹을 식별합니다.

Step 2) 그룹 삭제

1. 그룹 삭제:Bash

```
# 예: groupdel <그룹 이름>
sudo groupdel testgroup
```

2. 확인: `/etc/group` 및 `/etc/gshadow` 파일에서 해당 그룹이 제거되었는지 확인합니다.

2. [Ubuntu 24.04] 조치 방법

Step 1) 그룹 정보 및 멤버 확인

1. 그룹 목록 및 소속 사용자 확인:Bash

```
getent group
```

2. 불필요한 그룹 식별:

시스템 기본 그룹 외에 수동으로 생성되었으나 현재 사용되지 않는 그룹을 파악합니다.

Step 2) 그룹 제거 및 정리

1. 그룹 삭제:Bash

```
sudo delgroup <그룹 이름>
```

2. 그룹 권한 파일 확인 (선택 사항):

그룹 삭제 전, 해당 그룹 소유로 설정된 파일이 있는지 확인하여 권한 문제가 발생하지 않도록 조치합니다.Bash

```
# 특정 GID를 가진 파일 검색 (예: GID 1001)
find / -gid 1001 2>/dev/null
```

[U-23] SUID, SGID, Sticky bit 설정 파일 점검 가이드라인

수동 조치가 필요한 이유

SUID(Set User ID)나 SGID(Set Group ID)가 설정된 파일은 실행 시 파일 소유자(보통 root)의 권한으로 동작합니다. 만약 시스템에 기본적으로 필요한 파일 외에 악의적인 목적으로 생성된 파일이나 보안에 취약한 애플리케이션 파일에 이 권한이 부여되어 있다면, 일반 사용자가 이를 이용해 **root 권한을 획득(권한 상승)**할 수 있습니다.

어떤 파일이 시스템 운영에 필수적인지, 혹은 임의로 생성된 위험한 파일인지는 관리자의 정책적 판단이 필요하며, 무분별하게 권한을 제거할 경우 OS나 응용 프로그램이 정상적으로 작동하지 않을 수 있으므로 반드시 수동으로 검토 후 조치해야 합니다.

1. [Rocky Linux 9 / 10] 조치 방법

Step 1) SUID/SGID 설정 파일 검색

1. 시스템 내 root 소유의 특수 권한 파일 찾기:Bash

```
sudo find / -user root -type f \( -perm -04000 -o -perm -02000 \) -xdev -exec ls -al {} \;
```

2. 검토: 출력된 목록 중 시스템 기본 명령어(passwd, sudo 등) 외에 사용자가 임의로 생성한 파일이나 의심스러운 경로에 있는 파일을 식별합니다.

Step 2) 불필요한 특수 권한 제거

1. 권한 제거:Bash

```
# 예: sudo chmod -s <파일 이름>
sudo chmod -s /usr/local/bin/custom_script
```

Step 3) 특정 그룹으로 사용 제한 (필요 시)

- 반드시 root 권한으로 실행해야 하지만 일반 사용자 전체에게 노출하기 꺼려지는 경우, 특정 보안 그룹만 사용하도록 제한합니다.Bash

```
sudo chgrp admin_group /usr/bin/target_file
sudo chmod 4750 /usr/bin/target_file
```

2. [Ubuntu 24.04] 조치 방법

Step 1) 특수 권한 파일 리스트 추출

1. 권한 확인:Bash

```
sudo find / -type f \( -perm -4000 -o -perm -2000 \) -exec ls -al {} \;
```

2. 분석: Ubuntu의 기본 패키지 외에 /tmp, /var/tmp 등 쓰기 권한이 열린 디렉토리에 SUID 파일이 생성되어 있는지 중점적으로 확인합니다.

Step 2) 취약한 파일 조치

1. SUID/SGID 해제:Bash

```
sudo chmod u-s /path/to/file # SUID 제거
sudo chmod g-s /path/to/file # SGID 제거
```

Step 3) 서비스 영향도 확인

- 조치 후 관련 애플리케이션이나 시스템 서비스가 정상적으로 구동되는지 시스템 로그를 확인합니다.Bash

```
# Ubuntu 24.04 최신 로그 확인 방식
sudo journalctl -xe
```

⚠ 조치 시 주의사항 (공통)

- 시스템 핵심 파일 주의: /usr/bin/passwd, /usr/bin/sudo, /usr/bin/su 등은 SUID가 없으면 일반 사용자가 비밀번호를 변경하거나 권한을 얻을 수 없습니다. 이러한 표준 바이너리의 권한을 함부로 제거하지 마십시오.

- **Sticky Bit:** `/tmp` 와 같이 공용으로 사용하는 디렉토리에는 Sticky bit(`drwxrwxrwt`)가 설정되어 있어야 합니다. 이는 파일 소유자만 본인의 파일을 삭제할 수 있게 보장하므로, 공유 디렉토리의 Sticky bit는 유지하는 것이 보안상 유리합니다.
- **정기 점검:** 공격자는 백도어를 심을 때 SUID를 활용하는 경우가 많으므로, 이 목록을 주기적으로 백업하고 변동 사항을 감시하십시오.

[U-25] world writable 파일 점검 가이드라인

수동 조치가 필요한 이유

'world writable' 파일은 시스템의 모든 사용자(일반 사용자 및 비인가자 포함)에게 **쓰기 권한(777)**이 열려 있는 파일을 말합니다. 만약 시스템 설정 파일이나 실행 파일에 이 권한이 부여되어 있다면, 누구나 악의적인 코드를 삽입하거나 파일을 삭제하여 시스템을 마비시킬 수 있습니다.

자동화 도구로 단순히 모든 권한을 뺏을 경우, 프로그램 간 공유 데이터나 특정 서비스가 정상적으로 작동하지 않을 수 있습니다. 따라서 **어떤 파일이 왜 쓰기 권한이 열려 있는지 관리자가 직접 확인**하고, 불필요한 경우에만 권한을 제거하거나 파일을 삭제해야 합니다.

1. [Rocky Linux 9 / 10] 조치 방법

Step 1) world writable 파일 현황 점검

1. 시스템 내 모든 쓰기 허용 파일 찾기:Bash

```
sudo find / -type f -perm -2 -exec ls -l {} \;
```

2. 분석: 발견된 파일이 시스템 설정 파일(`/etc`), 바이너리 경로(`/bin` , `/usr/bin`), 또는 관리자 디렉토리에 있는지 확인합니다.

Step 2) 일반 사용자 쓰기 권한 제거

1. 권한 수정 (기타 사용자 쓰기 권한 제거):Bash

```
# 예: sudo chmod o-w <파일 이름>
sudo chmod o-w /path/to/vulnerable_file
```

Step 3) 불필요한 파일 삭제

1. 검토 후 삭제: 용도가 불분명하거나 임시로 생성된 파일인 경우 삭제합니다.Bash

```
sudo rm /path/to/unnecessary_file
```


2. [Ubuntu 24.04] 조치 방법

Step 1) 위험 파일 리스트 추출

1. 쓰기 권한 파일 검색: Bash

```
sudo find / -perm -o+w -type f -ls
```

2. 분석: Ubuntu 환경에서는 특정 애플리케이션 로그나 공유 자원 때문에 열려 있는 경우가 있으므로, 파일 소유자와 그룹을 먼저 확인합니다.

Step 2) 보안 조치 실행

1. 권한 강화: 상황에 따라 아래 명령 중 하나를 선택하여 적용합니다. Bash

```
# 소유자/그룹 외 타인의 쓰기 권한만 박탈  
sudo chmod 644 /path/to/file
```

```
# 또는 특정 파일의 쓰기 권한만 제거  
sudo chmod o-w /path/to/file
```

Step 3) 서비스 정상 작동 확인

- 권한 수정 후 관련 소프트웨어가 에러 없이 구동되는지 시스템 로그(`sudo journalctl -xe`) 등을 통해 점검합니다.

! 조치 시 주의사항 (공통)

- **심볼릭 링크 주의:** `find` 결과에 심볼릭 링크(l)가 포함될 수 있습니다. 링크 파일 자체의 권한보다는 **원본 파일의 권한**을 확인하고 수정해야 합니다.
- **특수 디렉토리 제외:** `/tmp`, `/var/tmp` 디렉토리 자체는 공유를 위해 쓰기 권한이 필요하지만, 그 안의 **일반 파일들**이 world writable인지는 반드시 점검해야 합니다.
- **장치 파일 제외:** `/dev` 디렉토리 내의 장치 파일들은 시스템 운영상 모든 사용자에게 쓰기 권한이 부여될 수 있으므로 조치 대상에서 제외하는 것이 일반적입니다.

[U-28] 접속 IP 및 포트 제한 가이드라인

수동 조치가 필요한 이유

네트워크 서비스(SSH, FTP 등)에 대해 접속 가능한 IP와 포트를 제한하지 않으면, 전 세계 어디서든 공격자가 무차별 대입 공격(Brute Force)이나 알려진 취약점을 이용해 침투를 시도할 수 있습니다.

단순히 포트를 여는 것뿐만 아니라, '**특정 신뢰할 수 있는 IP'만 허용**하도록 설정하는 것은 서버 보안의 가장 핵심적인 방어선입니다. 운영 환경에 따라 허용해야 할 IP가 모두 다르므로 관리자가 직접 정책을 검토하고 적용해야 합니다.

1. [Rocky Linux 9 / 10] 조치 방법

Rocky Linux는 기본 방화벽으로 **Firewalld**를 사용하며, 최신 버전에서는 `hosts.allow/deny` (TCP Wrapper) 방식보다 방화벽 자체 설정을 권장합니다.

Step 1) 현재 설정 확인

Bash

```
sudo firewall-cmd --list-all
```

Step 2) 특정 IP에 대해 특정 포트 허용 (Rich Rule)

예를 들어, SSH(22번 포트)를 특정 관리자 IP(`192.168.1.100`)에게만 허용하려면 아래와 같이 입력합니다.

1. **기본 서비스 제거 (필요 시):** 모든 IP에 열려 있는 기본 ssh 서비스를 먼저 닫아야 Rich Rule이 우선 적용됩니다.Bash

```
sudo firewall-cmd --permanent --remove-service=ssh
```

2. **Rich Rule 추가:**Bash

```
sudo firewall-cmd --permanent --add-rich-rule="rule family='ipv4' source address='192.168.1.100' port protocol='tcp' port='22' accept"
```

3. **정책 적용:**Bash

```
sudo firewall-cmd --reload
```

Step 3) 불필요한 서비스/포트 제거

- 모든 사용자에게 열려 있는 불필요한 서비스(예: ftp)를 제거합니다.Bash

```
sudo firewall-cmd --permanent --remove-service=ftp  
sudo firewall-cmd --reload
```

2. [Ubuntu 24.04] 조치 방법

Ubuntu는 관리가 간편한 ****UFW (Uncomplicated Firewall)****를 기본으로 사용합니다.

Step 1) 현재 설정 확인

Bash

```
sudo ufw status numbered
```

Step 2) 특정 IP 및 포트 허용 정책 추가

예를 들어, 특정 IP(`203.0.113.50`)에서만 8080 포트 접속을 허용하려면:

1. 규칙 추가:Bash

```
sudo ufw allow from 203.0.113.50 to any port 8080
```

2. SSH 접근 제한 (필수):

특정 사무실 IP(`192.168.10.0/24`)에서만 SSH를 허용하도록 설정합니다.Bash

```
sudo ufw allow from 192.168.10.0/24 to any port 22
```

Step 3) 기본 정책 설정 및 활성화

- 들어오는 모든 접속을 기본적으로 차단하도록 설정합니다.Bash

```
sudo ufw default deny incoming
sudo ufw reload
sudo ufw enable # 방화벽이 꺼져 있을 경우만 실행
```

! 조치 시 주의사항 (공통)

- 원격 접속 끊김 주의:** SSH 접속 IP를 잘못 제한하면 서버에 다시 접속할 수 없게 됩니다. 반드시 현재 접속 중인 세션을 유지한 채로 새로운 터미널 창에서 접속 테스트를 먼저 진행하십시오.
- 우선순위:** TCP Wrapper (`/etc/hosts.allow`)가 설치되어 있다면 방화벽 설정보다 먼저 적용될 수 있으므로, 두 설정이 충돌하지 않는지 확인하십시오.
- Permissive Policy:** 방화벽의 기본 정책(Default Policy)은 **모두 차단(Deny)**으로 설정하고, 필요한 IP/포트만 **명시적 허용(Allow)**하는 방식이 가장 안전합니다.

[U-33] 숨겨진 파일 및 디렉토리 검색 및 제거 가이드라인

수동 조치가 필요한 이유

리눅스에서 파일명이나 디렉토리명이 마침표(.)로 시작하면 일반적인 `ls` 명령어로는 보이지 않는 '숨겨진 상태'가 됩니다. 공격자들은 침투 후 자신의 흔적을 숨기거나 백도어, 악성 스크립트를 심어두기 위해 의도적으로 숨겨진 디렉토리(예: `...`, `.hash` 등)를 생성하는 경우가 많습니다.

하지만 시스템 운영에 필수적인 설정 파일(예: `.bashrc`, `.ssh` 등)도 숨겨진 형태이므로, 자동 삭제 시 시스템 장애가 발생할 수 있습니다. 따라서 **관리자가 직접 생성 목적을 확인하고 불필요한 파일인지 판단하는 과정이 반드시 필요합니다.**

1. [Rocky Linux 9 / 10] 조치 방법

Step 1) 숨겨진 파일 및 디렉토리 검색

1. 시스템 전체에서 숨겨진 파일 찾기:Bash

```
sudo find / -type f -name ".*" -xdev 2>/dev/null
```

2. 시스템 전체에서 숨겨진 디렉토리 찾기:Bash

```
sudo find / -type d -name ".*" -xdev 2>/dev/null
```

(참고: `-xdev` 옵션은 다른 파일 시스템(네트워크 드라이브 등)으로 넘어가지 않도록 제한하여 효율적으로 검색합니다.)

Step 2) 의심스러운 항목 식별 및 분석

- `/tmp`, `/var/tmp`, `/dev/shm` 과 같이 쓰기 권한이 열린 곳에 숨겨진 파일이 있다면 중점적으로 확인합니다.
- 파일의 내용을 확인하여 비정상적인 코드나 텍스트가 있는지 봅니다.Bash

```
# 파일 내용 확인 예시
sudo cat /tmp/.hidden_file
```

Step 3) 불필요한 파일 제거

1. 파일 또는 디렉토리 삭제:Bash

```
sudo rm -f /path/to/.suspicious_file
sudo rm -rf /path/to/.suspicious_dir
```

2. [Ubuntu 24.04] 조치 방법

Step 1) 특정 경로 및 홈 디렉토리 집중 점검

1. 사용자 홈 디렉토리 점검:Bash

```
ls -al /home/  
# 각 사용자 폴더 내 의심스러운 설정 파일이 있는지 확인
```

2. 공용 디렉토리 내 숨김 파일 검색:Bash

```
sudo find /tmp /var/tmp -name ".*" -ls
```

Step 2) 파일 속성 및 생성 시간 확인

- 파일이 생성된 시간과 최근 수정된 시간을 확인하여 침해 사고 의심 시간대와 비교합니다.Bash

```
stat /path/to/.hidden_file
```

Step 3) 조치 실행

1. 확인된 악성/불필요 파일을 삭제합니다.

! 조치 시 주의사항 (공통)

- **삭제 주의 항목:** 시스템 운영 및 사용자 환경 설정을 담당하는 아래 파일들은 **절대로 함부로 삭제해서는 안 됩니다.**
 - `.bashrc` , `.bash_profile` , `.profile`
 - `.ssh` (원격 접속 키 관련)
 - `.bash_history` (명령어 이력)
 - `.gnupg` , `.local` , `.cache` 등 (사용자 환경 데이터)
- **특이한 이름 주의:** 공격자는 눈속임을 위해 `..` (마침표 두 개와 공백)이나 `...` 같은 이름으로 폴더를 만들기도 하므로 세밀한 관찰이 필요합니다.
- **백업:** 확실치 않은 파일은 바로 삭제하기보다 다른 경로로 이동시켜 두고 서비스 영향도를 관찰하는 것이 안전합니다.

[U-40] NFS 접근 통제 가이드라인

💡 수동 조치가 필요한 이유

NFS(Network File System)는 원격 서버의 디렉토리를 로컬 시스템처럼 마운트하여 사용할 수 있게 해주는 편리한 서비스입니다. 하지만 접근 통제(IP 제한, 권한 설정 등)가 제대로 되어 있지 않으면 비인가자가 중요 데이터를 변조하거나 유출할 수 있는 치명적인 약점이 됩니다.

특히 NFS 설정 파일(`/etc/exports`)의 권한이 과도하게 설정되어 있으면 일반 사용자가 허용 리스트를 조작할 위험이 있으므로, **관리자가 직접 파일 권한과 공유 대상 IP를 수동으로 점검**해야 합니다.

1. [Rocky Linux 9 / 10] 조치 방법

Step 1) NFS 서비스 사용 여부 확인

NFS를 사용하지 않는다면 서비스를 중지하고 비활성화하는 것이 가장 안전합니다.

Bash

```
sudo systemctl stop nfs-server
sudo systemctl disable nfs-server
```

Step 2) NFS 설정 파일 권한 조치

NFS를 사용해야 하는 경우, 설정 파일의 소유자와 권한을 강화합니다.

1. 소유자 변경: `sudo chown root /etc/exports`
2. 권한 변경: `sudo chmod 644 /etc/exports`

Step 3) 접근 통제 설정 수정

1. 파일 편집: `sudo vi /etc/exports`
2. 보안 설정 적용: 특정 호스트만 읽기 전용(`ro`)으로 접근 가능하게 하고, root 권한을 일반 사용자 권한으로 매핑(`root_squash`)합니다.
 - 예시: `/data_share 192.168.1.10(ro,root_squash)`
3. 설정 적용: `sudo exportfs -ra`

2. [Ubuntu 24.04] 조치 방법

Step 1) 불필요한 NFS 서비스 제거

사용하지 않는 경우 패키지 삭제 또는 서비스 중지를 수행합니다.

Bash

```
sudo systemctl stop nfs-kernel-server
sudo systemctl disable nfs-kernel-server
```

Step 2) 설정 파일 보안 점검

1. 권한 확인: `ls -l /etc/exports` (권한이 644인지 확인)
2. 권한 수정: Bash

```
sudo chown root:root /etc/exports
sudo chmod 644 /etc/exports
```

Step 3) 공유 디렉터리 권한 강화

1. 파일 편집: `sudo nano /etc/exports`
2. 옵션 상세 설정:
 - `root_squash`: 원격 root 사용자를 anonymous 사용자로 취급 (필수 권장)
 - `secure`: 1024 이하의 포트로부터만 접속 허용
 - 예시: `/shared_folder 10.0.0.5(rw,sync,root_squash,secure)`
3. 변경사항 반영: `sudo exportfs -ra`

⚠ 조치 시 주의사항 (공통)

- **NFS v4 권장**: NFS v2, v3는 보안상 취약하므로 가급적 암호화 및 강화된 인증을 지원하는 **NFS v4**를 사용하십시오.
- **접근 호스트 명시**: (와일드카드)를 사용하여 모든 대역에 공유하는 것은 매우 위험합니다. 반드시 특정 IP 주소나 서브넷을 명시하십시오.
- **불필요한 디렉터리 공유 금지**: `/`, `/etc`, `/usr` 등 시스템 중요 디렉터리는 절대로 NFS로 공유해서는 안 됩니다.
- **root_squash 확인**: 이 옵션이 없으면 원격 사용자가 마운트된 디렉터리 내에서 root 권한을 그대로 행사할 수 있으므로 반드시 포함되어 있는지 확인하십시오.

🛡 [U-45] 메일 서비스 버전 점검 가이드라인

💡 수동 조치가 필요한 이유

Sendmail, Postfix, Exim과 같은 메일 서비스(MTA)는 외부 네트워크와 직접 통신하므로 취약점이 발견될 경우 **버퍼 오버플로우** 공격을 통해 시스템 권한을 탈취당할 위험이 매우 높습니다.

자동화된 업데이트가 설정되어 있지 않다면 관리자가 직접 현재 실행 중인 서비스 종류를 파악하고, 최신 보안 패치가 적용되었는지 수동으로 확인해야 합니다. 특히 사용하지 않는 메일 서비스가 백그라운드에서 구동 중이라면 즉시 중지해야 합니다.

1. [Rocky Linux 9 / 10] 조치 방법

Rocky Linux는 기본 MTA로 주로 **Postfix**를 사용합니다.

Step 1) 메일 서비스 사용 여부 확인

메일 서버 운영 목적이 없다면 서비스를 중지하고 비활성화합니다.

Bash

```
# Postfix 사용 시
sudo systemctl stop postfix
sudo systemctl disable postfix
```

```
# Sendmail 사용 시 (설치된 경우)
sudo systemctl stop sendmail
sudo systemctl disable sendmail
```

Step 2) 버전 확인 및 업데이트 (사용 시)

메일 서비스를 운영해야 한다면 최신 패키지로 업데이트합니다.

1. 버전 확인:Bash

```
postconf mail_version # Postfix 기준
```

2. 패키지 업데이트:Bash

```
sudo dnf update postfix -y
```

2. [Ubuntu 24.04] 조치 방법

Ubuntu는 설치 환경에 따라 **Postfix**나 **Exim4**를 사용합니다.

Step 1) 활성화된 메일 서비스 확인

Bash

```
systemctl list-units --type=service | grep -E 'postfix|exim|sendmail'
```

Step 2) 미사용 서비스 중지 및 비활성화

사용하지 않는 메일 서비스가 확인되면 아래 명령어로 정리합니다.

Bash

```
sudo systemctl stop exim4
sudo systemctl disable exim4
# 또는 postfix인 경우
sudo systemctl stop postfix
sudo systemctl disable postfix
```

Step 3) 보안 패치 적용 (사용 시)

Bash

```
sudo apt update
sudo apt install --only-upgrade postfix # 또는 exim4
```

⚠ 조치 시 주의사항 (공통)

- **Kill 명령어 주의:** `kill -9` 는 프로세스를 강제 종료하므로 데이터가 유실될 수 있습니다. 가급적 `systemctl stop` 명령어를 먼저 사용하고, 서비스가 응답하지 않을 때만 최후의 수단으로 `kill` 을 사용하십시오.
- **불필요한 중복 설치:** 한 서버에 여러 종류의 MTA(Postfix와 Sendmail 등)가 동시에 돌아가지 않도록 관리하십시오. 포트 충돌 및 보안 관리의 복잡성을 초래합니다.
- **릴레이 설정 확인:** 버전 업데이트만큼 중요한 것이 **Open Relay(제3자의 메일 발송 허용)** 방지 설정입니다. 업데이트 후 설정 파일(`main.cf` 등)이 초기화되지 않았는지 확인하십시오.

🛡 [U-47] 스팸 메일 릴레이 제한 가이드라인

💡 수동 조치가 필요한 이유

메일 릴레이(Relay)란 외부에서 보낸 메일을 SMTP 서버가 수신하여 다른 목적지로 전달해주는 기능을 말합니다. 이 기능이 제한 없이 모든 사용자에게 열려 있으면(Open Relay), 공격자가 해당 서버를 스팸 메일 발송 통로로 악용하거나 DoS 공격의 수단으로 사용할 수 있습니다.

자동화된 설정만으로는 내부망의 정당한 릴레이 허용 대역을 구분하기 어렵기 때문에, **관리자가 직접 신뢰할 수 있는 IP 대역을 정의하고 릴레이 제한 정책을 적용**해야 합니다.

1. [Rocky Linux 9 / 10] 조치 방법

Rocky Linux는 기본 MTA로 **Postfix**를 주로 사용합니다.

Step 1) 메일 서비스 미사용 시

메일 서버 운영 계획이 없다면 서비스를 중지하여 위험을 원천 차단합니다.

Bash

```
sudo systemctl stop postfix
sudo systemctl disable postfix
```

Step 2) Postfix 릴레이 제한 설정 (사용 시)

1. 설정 파일 열기: Bash

```
sudo vi /etc/postfix/main.cf
```

2. 신뢰 네트워크 설정: `mynetworks` 설정을 찾아 내부 루프백 주소와 실제 신뢰하는 네트워크 대역만 지정합니다. Plaintext

```
# 예: 자기 자신과 특정 내부 대역만 허용
mynetworks = 127.0.0.0/8, 192.168.1.0/24
```

3. 수신 제한 설정 확인: `smtpd_recipient_restrictions` 항목에 `permit_mynetworks` 와 `reject_unauth_destination` 이 포함되어 있는지 확인합니다. Plaintext

```
smtpd_recipient_restrictions = permit_mynetworks, reject_unauth_destination
```

4. 설정 적용: Bash

```
sudo postfix reload
```

2. [Ubuntu 24.04] 조치 방법

Ubuntu는 설치 환경에 따라 **Postfix** 또는 **Exim4**를 사용합니다.

Step 1) Postfix 사용 시 조치

- 위 Rocky Linux의 Postfix 조치 방법과 동일하게 `/etc/postfix/main.cf` 파일을 수정합니다.

Step 2) Exim4 사용 시 조치

1. 설정 파일 열기: Bash

```
sudo vi /etc/exim4/exim4.conf.template # 또는 구성 방식에 따라 /etc/exim4/update-exim4.conf.conf
```

2. 릴레이 허용 호스트 지정: `dc_relay_nets` 또는 `relay_from_hosts` 항목에 허용할 대역을 입력합니다. Plaintext

```
# 예시
dc_relay_nets='192.168.1.0/24'
```

3. 설정 업데이트 및 재시작: Bash

```
sudo update-exim4.conf
sudo systemctl restart exim4
```

3. Sendmail 사용 시 공통 조치 (버전 공통)

만약 Sendmail을 직접 설치하여 사용 중이라면 아래 절차를 따릅니다.

1. 릴레이 거부 설정 확인: `/etc/mail/sendmail.mc` 파일에서 `promiscuous_relay` 설정이 있다면 삭제합니다.

2. 접근 제어 리스트(ACL) 수정:Bash

```
sudo vi /etc/mail/access
```

- `Connect:127.0.0.1 RELAY` (허용)
- `Connect:192.168.1 RELAY` (특정 대역 허용)
- `Connect:spam.com REJECT` (특정 도메인 차단)

3. DB 갱신 및 재시작:Bash

```
sudo makemap hash /etc/mail/access.db < /etc/mail/access
sudo systemctl restart sendmail
```

⚠ 조치 시 주의사항 (공통)

- 릴레이 테스트: 조치 후 외부망 IP에서 해당 서버를 통해 외부 메일 주소로 메일 발송이 거부되는지 반드시 확인해야 합니다. (Open Relay Test 도구 활용 권장)
- 릴레이 대역 최소화: `mynetworks` 나 `relay_nets` 에 `0.0.0.0/0` 과 같이 전체 대역을 넣는 것은 매우 위험합니다.
- 로그 모니터링: 릴레이 거부 로그(`Relaying denied`)가 특정 IP에서 과도하게 발생하는지 주기적으로 확인하여 공격 시도를 탐지하십시오.

🛡 [U-49] DNS 보안 버전 패치 가이드라인

💡 수동 조치가 필요한 이유

BIND(Berkeley Internet Name Domain)는 전 세계적으로 가장 많이 사용되는 DNS 서버 소프트웨어이지만, 그만큼 공격자의 주요 타겟이 되기도 합니다. 취약한 버전을 사용할

경우 **DoS(서비스 거부 공격)**, **버퍼 오버플로우**, 또는 ****원격 코드 실행(RCE)****을 통해 서버 전체의 제어권을 탈취당할 위험이 매우 높습니다.

DNS는 인터넷 서비스의 이정표 역할을 하므로, 잘못된 패치나 설정은 서비스 중단으로 이어질 수 있습니다. 따라서 **관리자가 직접 현재 버전을 확인하고, 서비스 영향도를 고려하여 수동으로 보안 패치를 적용**해야 합니다.

1. [Rocky Linux 9 / 10] 조치 방법

Rocky Linux는 기본적으로 **bind** 패키지를 통해 DNS 서비스를 제공합니다.

Step 1) DNS 서비스 활성화 여부 확인

DNS 서버를 직접 운영하지 않는다면 서비스를 중지하고 비활성화하여 잠재적 위협을 제거합니다.

Bash

```
sudo systemctl stop named
sudo systemctl disable named
```

Step 2) BIND 버전 확인 및 패치 (사용 시)

BIND 서비스를 운영해야 하는 경우, 현재 버전을 확인하고 최신 패키지로 업데이트합니다.

1. 버전 확인:Bash

```
named -v
```

2. 보안 패치 및 업데이트:Bash

```
sudo dnf update bind -y
```

3. 서비스 재시작:Bash

```
sudo systemctl restart named
```

2. [Ubuntu 24.04] 조치 방법

Ubuntu 환경에서도 BIND9 패키지를 주로 사용하며, 보안 업데이트는 **apt**를 통해 관리됩니다.

Step 1) 서비스 상태 확인 및 중지 (미사용 시)

Bash

```
sudo systemctl status named
# 미사용 시 조치
sudo systemctl stop named
sudo systemctl disable named
```

Step 2) 최신 보안 업데이트 적용 (사용 시)

1. 현재 버전 확인:Bash

```
named -v
```

2. 보안 패치 적용:Bash

```
sudo apt update  
sudo apt install --only-upgrade bind9
```

3. 설정 유효성 검사 및 재시작:Bash

```
# 설정 파일 오류 검사  
sudo named-checkconf  
sudo systemctl restart named
```

! 조치 시 주의사항 (공통)

- **취약점 정보 상시 확인:** ISC 홈페이지(<https://www.isc.org/>) 또는 BIND 9 Vulnerability Matrix를 주기적으로 방문하여 사용하는 버전에 대한 새로운 보안 권고문이 있는지 확인하십시오.
- **설정 파일 백업:** 패키지 업데이트 과정에서 기존 설정 파일(`/etc/named.conf` 등)이 변경되거나 덮어쓰워질 수 있으므로 반드시 사전에 백업을 생성하십시오.
- **Zone 파일 권한 점검:** 업데이트 후 네임 서버의 Zone 데이터 파일에 대한 권한이 root 또는 named 계정으로 적절히 유지되고 있는지 확인하십시오.
- **서비스 영향도 테스트:** DNS는 매우 민감한 서비스이므로, 운영 환경에 적용하기 전 스테이징 서버에서 쿼리 응답 및 재시작 테스트를 충분히 거쳐야 합니다.

[U-50] DNS Zone Transfer 설정 가이드라인

수동 조치가 필요한 이유

Zone Transfer(영역 전송)는 주(Primary) 이름 서버와 보조(Secondary) 이름 서버 간에 데이터를 동기화하는 기능입니다. 만약 이 설정을 모든 사용자에게 허용(Any)할 경우, 공격자가 `dig` 명령 등을 통해 해당 도메인에 등록된 **모든 호스트 정보, 내부 IP 주소, 시스템 정보**를 한꺼번에 수집할 수 있는 '정보 노출'의 치명적인 원인이 됩니다.

보조 이름 서버의 IP 주소는 운영 환경마다 다르므로, **관리자가 신뢰할 수 있는 보조 서버의 IP를 직접 지정**하여 전송 대상을 제한해야 합니다.

1. [Rocky Linux 9 / 10] 조치 방법

Rocky Linux의 BIND 설정은 주로 `/etc/named.conf` 에서 관리합니다.

Step 1) 전송 제한 설정 확인

Bash

```
sudo grep -i "allow-transfer" /etc/named.conf
```

Step 2) 설정 수정 (보조 서버 IP 제한)

1. 설정 파일 열기: `sudo vi /etc/named.conf`
2. **Global** 설정 수정: `options` 섹션 내에 허용할 보조 서버 IP를 입력합니다.Plaintext

```
options {  
    ...  
    # 보조 서버 IP가 192.168.1.50인 경우  
    allow-transfer { localhost; 192.168.1.50; };  
    ...  
};
```

보조 서버가 없다면 `none;` 으로 설정하는 것이 가장 안전합니다.

Step 3) 서비스 재시작

Bash

```
sudo named-checkconf # 설정 오류 검사  
sudo systemctl restart named
```

2. [Ubuntu 24.04] 조치 방법

Ubuntu의 BIND9 설정은 주로 `/etc/bind/named.conf.options` 또는 각 영역(zone) 설정 파일에서 관리합니다.

Step 1) 전송 제한 설정 확인

Bash

```
sudo grep -ri "allow-transfer" /etc/bind/
```

Step 2) 설정 수정

1. 옵션 파일 열기: `sudo vi /etc/bind/named.conf.options`
2. 설정 추가/수정:Plaintext

```
options {  
    ...  
    allow-transfer { 127.0.0.1; <보조_서버_IP>; };  
}
```

```
...  
};
```

3. **Zone별 개별 설정 (필요 시)**: 특정 도메인에 대해서만 설정을 별도로 두려면 `/etc/bind/named.conf.local` 에서 해당 zone 섹션에 추가합니다.

Step 3) 서비스 재시작

Bash

```
sudo named-checkconf  
sudo systemctl restart bind9
```

⚠ 조치 시 주의사항 (공통)

- **보조 서버 동기화 확인**: 설정을 바꾼 후 보조 이름 서버에서 주 서버의 데이터를 정상적으로 받아오는지 반드시 확인하십시오. (`journalctl -u named` 로그 확인)
- **우선순위**: `options` 섹션의 설정보다 각 `zone` 섹션 내의 `allow-transfer` 설정이 우선 적용됩니다. 전체 설정을 바꿨더라도 개별 zone 설정에 `any;` 가 들어가 있지 않은지 확인하십시오.
- **불필요한 서비스 중지**: DNS 서버를 운영하지 않는다면 서비스를 중지하는 것이 최선입니다. (`systemctl stop named`)
- **기존 설정(named.boot)**: 가이드라인에 언급된 `named.boot` 는 매우 오래된 방식(BIND 4)이므로, 최신 OS인 Rocky 9나 Ubuntu 24.04에서는 무시하고 `named.conf` 파일을 수정하면 됩니다.

🛡 [U-51] DNS 서비스의 취약한 동적 업데이트 설정 금지 가이드라인

💡 수동 조치가 필요한 이유

DNS 동적 업데이트(Dynamic Update)는 클라이언트가 자신의 리소스 레코드를 DNS 서버에 자동으로 등록하거나 수정할 수 있게 해주는 기능입니다. 하지만 이 설정이 적절한 인증이나 IP 제한 없이 모든 사용자에게 열려 있다면, 공격자가 가짜 레코드를 등록하여 사용자를 악성 사이트로 유도(DNS 스푸핑)하거나 기존 정보를 삭제하는 등 DNS 체계를 완전히 무너뜨릴 수 있습니다.

일반적인 고정 IP 환경의 서버 운영에서는 이 기능이 필요하지 않은 경우가 많으므로, 관리자가 직접 동적 업데이트 허용 여부를 검토하고 필요 시 특정 대역으로만 엄격히 제한해야 합니다.

1. [Rocky Linux 9 / 10] 조치 방법

Rocky Linux의 BIND 설정 파일은 주로 `/etc/named.conf` 및 `/var/named/` 하위의 zone 파일에 위치합니다.

Step 1) 동적 업데이트 설정 확인

설정 파일 내에서 `allow-update` 키워드를 검색합니다.

Bash

```
sudo grep -ri "allow-update" /etc/named.conf /etc/named.rfc1912.zones
```

Step 2) 동적 업데이트 비활성화 (권장)

동적 업데이트 기능이 필요 없다면 `none` 으로 설정합니다.

1. 설정 파일 열기: `sudo vi /etc/named.conf`
2. 설정 수정: `options` 섹션 혹은 개별 `zone` 섹션에 아래 내용을 추가/수정합니다.Plaintext

```
allow-update { none; };
```

Step 3) 동적 업데이트 활성화 (필요 시)

반드시 사용해야 한다면 신뢰할 수 있는 특정 호스트의 IP만 허용합니다.

Plaintext

```
# 예: 192.168.1.100 호스트만 허용
allow-update { 192.168.1.100; };
```

Step 4) 설정 적용 및 재시작

Bash

```
sudo named-checkconf
sudo systemctl restart named
```

2. [Ubuntu 24.04] 조치 방법

Ubuntu의 BIND9 설정은 주로 `/etc/bind/` 디렉토리 내 파일들을 사용합니다.

Step 1) 동적 업데이트 설정 점검

Bash

```
sudo grep -ri "allow-update" /etc/bind/
```

Step 2) 설정 수정

1. 설정 파일 열기: `sudo vi /etc/bind/named.conf.options` (또는 해당 zone 파일)
2. 보안 강화: Plaintext

```
zone "example.com" {  
    type master;  
    file "/etc/bind/db.example.com";  
    allow-update { none; }; # 동적 업데이트 금지  
};
```

Step 3) 서비스 재시작

Bash

```
sudo named-checkconf  
sudo systemctl restart bind9
```

⚠ 조치 시 주의사항 (공통)

- **Zone 파일 권한:** 동적 업데이트를 허용할 경우, BIND 프로세스 계정(`named` 또는 `bind`)이 해당 zone 파일 및 디렉토리에 대해 쓰기 권한을 가지고 있어야 합니다.
- **TSIG(Transaction Signature) 권장:** IP 기반의 `allow-update`는 IP 스푸핑에 취약할 수 있습니다. 보안이 중요한 환경에서 동적 업데이트가 꼭 필요하다면 **TSIG 키를 이용한 인증 방식** 설정을 강력히 권장합니다.
- **Default 값 인지:** BIND의 기본값은 동적 업데이트가 허용되지 않는 것이지만, 설정 파일에 명시적으로 `any;` 등이 포함되어 유출되는 사고를 방지하기 위해 반드시 수동으로 점검해야 합니다.
- **Journal 파일:** 동적 업데이트가 활성화된 경우 `.jnl` 확장자의 저널 파일이 생성됩니다. 이 파일들이 비정상적으로 생성되고 있다면 무단 업데이트 시도가 있는지 로그를 확인하십시오.

[U-56] FTP 서비스 접근 제어 설정 가이드라인

수동 조치가 필요한 이유

FTP는 아이디와 비밀번호가 암호화되지 않은 채 평문으로 전송되는 보안에 매우 취약한 프로토콜입니다. 주요 정보 통신 기반 시설에서는 사용 금지가 원칙이나, 업무상 불가피하게 사용할 경우 **비인가자의 접근을 차단하는 강력한 접근 제어**가 필수적입니다.

특히 root 계정 등 주요 계정의 접속을 차단하는 `ftputers` 설정 파일이 일반 사용자에게 노출되거나 수정 가능할 경우, 공격자가 이를 악용해 중요 파일에 접근할 수 있으므로 **관리자가 직접 파일 권한과 접속 허용 리스트를 수동으로 점검**해야 합니다.

1. [Rocky Linux 9 / 10] 조치 방법

Rocky Linux는 주로 **vsFTPD**를 사용합니다.

Step 1) FTP 서비스 미사용 시 조치

서비스를 중지하고 비활성화하여 잠재적 위협을 제거합니다.

Bash

```
sudo systemctl stop vsftpd
sudo systemctl disable vsftpd
```

Step 2) vsFTPD 접근 제어 설정 (사용 시)

1. 설정 파일 권한 강화: Bash

```
sudo chown root /etc/vsftpd/ftputers /etc/vsftpd/user_list
sudo chmod 640 /etc/vsftpd/ftputers /etc/vsftpd/user_list
```

2. 주요 계정 접속 차단: `/etc/vsftpd/ftputers` 파일에 `root`, `bin`, `sys` 등 시스템 계정이 포함되어 있는지 확인합니다.

3. 접근 제어 방식 설정: `/etc/vsftpd/vsftpd.conf` 를 수정합니다.

- **White-list 방식 (권장):** 등록된 사용자만 허용 Plaintext

```
userlist_enable=YES
userlist_deny=NO
```

4. 서비스 재시작: `sudo systemctl restart vsftpd`

2. [Ubuntu 24.04] 조치 방법

Ubuntu에서도 **vsFTPD**를 주로 사용하며, 설정 파일 경로가 약간 다를 수 있습니다.

Step 1) FTP 서비스 상태 확인 및 중지

Bash

```
sudo systemctl status vsftpd
# 미사용 시
sudo systemctl stop vsftpd
sudo systemctl disable vsftpd
```

Step 2) 접근 제한 파일 점검

1. 파일 확인: Ubuntu는 보통 `/etc/ftpusers` 경로를 공통으로 사용합니다.
2. 소유자 및 권한 수정: Bash

```
sudo chown root:root /etc/ftpusers
sudo chmod 640 /etc/ftpusers
```

Step 3) 특정 IP/호스트 접근 제한 (TCP Wrapper)

방화벽(UFW)을 사용하여 특정 IP에서만 FTP 포트(21)에 접근하도록 제한합니다.

Bash

```
# 특정 관리자 IP(192.168.1.10)만 허용
sudo ufw allow from 192.168.1.10 to any port 21
sudo ufw reload
```

⚠ 조치 시 주의사항 (공통)

- **SFTP/FTPS 권장:** FTP는 보안상 매우 위험합니다. 가급적 SSH를 이용하는 **SFTP**나 암호화가 적용된 **FTPS**로 전환할 것을 강력히 권고합니다.
- **Anonymous 접속 차단:** 설정 파일 내 `anonymous_enable=NO` 설정이 되어 있는지 반드시 확인하십시오. 익명 접속이 허용되면 누구나 서버 파일에 접근할 수 있습니다.
- **ftpusers vs user_list:**
 - `ftpusers`: 여기에 적힌 사용자는 **무조건 접속 거부**됩니다. (PAM 모듈 기반)
 - `user_list`: `userlist_deny` 옵션에 따라 **허용(White-list)** 또는 **차단(Black-list)** 리스트로 동작합니다.
- **root 접속 차단:** 보안 가이드라인 준수를 위해 `root` 계정은 반드시 `ftpusers`에 등록하여 접속을 차단하십시오.

🛡 [U-61] SNMP Access Control 설정 가이드라인

💡 수동 조치가 필요한 이유

SNMP(Simple Network Management Protocol)는 네트워크 장비나 서버의 상태를 모니터링하는 데 유용하지만, 접근 제어 설정이 미흡할 경우 치명적인 보안 허점이 됩니다. 특히 기본 설정(Community String)인 `public` 이나 `private` 을 그대로 사용하거나 모든 대역의 접근을 허용하면, 공격자가 시스템 사양, 네트워크 구성, 프로세스 정보 등을 탈취하고 심지어 시스템 설정을 임의로 변경할 수 있습니다.

따라서 **관리자가 직접 신뢰할 수 있는 매니저(NMS) IP 대역을 지정**하고, 추측하기 어려운 복잡한 Community String을 설정하는 수동 조치가 반드시 필요합니다.

1. [Rocky Linux 9 / 10] 조치 방법

Rocky Linux(Redhat 계열)는 `/etc/snmp/snmpd.conf` 파일의 `com2sec` 설정을 통해 접근을 제어합니다.

Step 1) SNMP 서비스 미사용 시

모니터링이 필요 없는 서버라면 서비스를 중지하여 위험을 제거합니다.

Bash

```
sudo systemctl stop snmpd
sudo systemctl disable snmpd
```

Step 2) SNMP 접근 제어 설정 (사용 시)

1. 설정 파일 열기: `sudo vi /etc/snmp/snmpd.conf`

2. 접근 허용 대역 및 Community String 수정:Plaintext

- 기본값인 `public` 을 삭제하고, 특정 IP 대역만 허용하도록 `com2sec` 라인을 수정합니다.

```
# com2sec [보안이름] [허용할 호스트/네트워크] [Community String]
com2sec local_user 127.0.0.1 MyComplexString!
com2sec nms_user 192.168.10.0/24 MyComplexString!
```

3. 서비스 재시작:Bash

```
sudo systemctl restart snmpd
```

2. [Ubuntu 24.04] 조치 방법

Ubuntu(Debian 계열)는 주로 `rocommunity` , `rwcommunity` 지시어를 사용하여 간결하게 설정합니다.

Step 1) SNMP 서비스 상태 확인 및 중지

Bash

```
sudo systemctl status snmpd
# 미사용 시 조치
sudo systemctl stop snmpd
sudo systemctl disable snmpd
```

Step 2) 커뮤니티 스트링 및 접근 IP 제한

1. 설정 파일 열기: `sudo vi /etc/snmp/snmpd.conf`

2. 읽기 전용(RO) 접근 제한 설정: Plaintext

- 기존의 `rocommunity public default` 라인을 주석 처리하거나 삭제한 후, 허용할 IP 대역을 명시합니다.

```
# rocommunity [Community String] [허용할 IP/대역]
rocommunity MyStrongReadOnlyKey 192.168.10.50
```

3. 쓰기(RW) 권한 제한: 쓰기 권한은 가급적 사용하지 않는 것이 안전하며, 필요하다면 매우 엄격하게 제한합니다. Plaintext

```
rwcommunity MyStrongWriteKey 192.168.10.50
```

4. 서비스 재시작: Bash

```
sudo systemctl restart snmpd
```

! 조치 시 주의사항 (공통)

- **Default 값 변경 필수:** `public`, `private` 등 누구나 알 법한 Community String은 절대 사용하지 마십시오.
- **SNMP v3 권장:** SNMP v1, v2c는 정보가 평문으로 전송됩니다. 가능하다면 사용자 인증과 암호화를 지원하는 **SNMP v3** 사용을 강력히 권장합니다.
- **방화벽 설정 병행:** 설정 파일 수정 외에도 시스템 방화벽(Firewalld/UFW)을 통해 **UDP 161, 162 포트**에 대한 접근을 특정 IP로만 제한하십시오.
 - (Rocky 예시) `sudo firewall-cmd --permanent --add-rich-rule="rule family='ipv4' source address='192.168.10.50' port protocol='udp' port='161' accept"`
- **최소 권한 원칙:** 정보를 수집하는 목적이라면 `rwcommunity` 대신 반드시 `rocommunity` 를 사용하십시오.

[U-64] 주기적 보안 패치 및 벤더 권고사항 적용 가이드라인

수동 조치가 필요한 이유

운영체제와 커널에서 발견되는 취약점은 공격자가 시스템 권한을 획득하거나 정보를 유출하는 가장 주된 경로입니다. 특히 '알려진 취약점(1-day 취약점)'은 패치가 발표되었음에도 적용하지 않은 서버를 대상으로 공격이 집중됩니다.

하지만 서버 환경에서는 최신 패치 적용 시 특정 애플리케이션과의 호환성 문제로 서비스가 중단될 위험이 있습니다. 따라서 **관리자가 직접 OS 및 커널의 수명 주기(EOL)를 확인하고, 보안 업데이트 내역을 검토한 후 영향도 테스트를 거쳐 수동으로 패치를 적용하는 정책**이 반드시 필요합니다.

1. [Rocky Linux 9 / 10] 조치 방법

Rocky Linux는 `dnf` 패키지 매니저를 통해 보안 패치를 관리합니다.

Step 1) 버전 및 커널 확인

Bash

```
hostnamectl  
# 또는  
uname -r
```

Step 2) 보안 업데이트 목록 확인

전체 업데이트 대신 **보안 관련 패치**만 선별해서 확인합니다.

Bash

```
sudo dnf updateinfo list security
```

Step 3) 패치 적용

1. 보안 패치만 적용 (권장): Bash

```
sudo dnf update --security -y
```

2. 커널 포함 전체 업데이트: 서비스 영향도를 검토한 후 진행합니다. Bash

```
sudo dnf update -y
```

2. [Ubuntu 24.04] 조치 방법

Ubuntu는 `apt` 매니저를 사용하며, 보안 패치를 주기적으로 확인해야 합니다.

Step 1) 시스템 정보 및 EOL 확인

Bash

```
lsb_release -a  
# 현재 버전의 지원 기간을 확인합니다.
```

Step 2) 보안 패치 확인 및 적용

1. 패키지 리스트 갱신:Bash

```
sudo apt update
```

2. 보안 업데이트 설치:Bash

```
# 보안 패치 항목만 업그레이드  
sudo apt-get install --only-upgrade <패키지명>  
# 또는 전체 업그레이드  
sudo apt upgrade -y
```

Step 3) 커널 업데이트 후 재부팅

커널 패치는 적용 후 시스템 재부팅이 완료되어야 활성화됩니다.

Bash

```
sudo reboot
```

⚠ 조치 시 주의사항 (공통)

- **스테이징 테스트 필수:** 운영 서버에 패치를 적용하기 전, 동일한 환경의 테스트 서버 (Staging)에서 애플리케이션 정상 작동 여부를 반드시 확인하십시오.
- **백업 생성:** 패치 작업 전 중요한 데이터와 설정 파일, 혹은 가상머신의 경우 **스냅샷 (Snapshot)**을 반드시 생성하십시오.
- **EOL(End of Life) 확인:** 사용 중인 OS 버전이 벤더로부터 더 이상 보안 지원을 받지 못하는 EOL 상태라면, 즉시 지원 가능한 상위 버전으로 마이그레이션을 계획해야 합니다.
- **자동 업데이트 주의:** `unattended-upgrades` 같은 자동 패치 기능은 편리하지만, 의도치 않은 서비스 중단을 초래할 수 있으므로 중요도가 높은 서버는 수동 관리를 권장합니다.

🛡 [U-66] 정책에 따른 시스템 로깅 설정 가이드라인

💡 수동 조치가 필요한 이유

시스템 로그는 침해 사고 발생 시 공격자의 유입 경로, 작업 내역, 유출 데이터를 파악할 수 있는 유일한 '블랙박스' 역할을 합니다. 로깅 설정이 부실하면 사고 원인 규명이 불가능하며, 법적 대응 시 증거 능력을 인정받기 어렵습니다.

시스템 성능과 저장 공간의 한계로 인해 모든 로그를 무한정 남길 수는 없으므로, 관리자가 직접 조직의 보안 정책에 맞춰 필수적인 로그 항목(인증, 보안, 메일, 커널 등)이 정확한 경로에 기록되도록 수동으로 구성해야 합니다.

1. [Rocky Linux 9 / 10] 조치 방법

Rocky Linux는 기본적으로 `rsyslog`를 사용하여 로그를 관리합니다.

Step 1) rsyslog 설정 확인 및 수정

1. 설정 파일 열기: `sudo vi /etc/rsyslog.conf`
2. 로그 기록 정책 추가/수정: 아래의 표준 권고 설정을 확인하여 누락된 부분을 추가합니다.Plaintext

```
# 모든 정보성 로그를 messages에 기록 (단, 메일/인증/작업스케줄 제외)
*.info;mail.none;authpriv.none;cron.none /var/log/messages

# 인증 및 보안 관련 로그 (가장 중요)
authpriv.* /var/log/secure

# 메일 시스템 로그
mail.* /var/log/maillog

# 예약 작업(Cron) 로그
cron.* /var/log/cron

# 치명적 오류 발생 시 모든 사용자에게 알림
*.emerg :omusrmsg:*
```

Step 2) 서비스 재시작

Bash

```
sudo systemctl restart rsyslog
```

2. [Ubuntu 24.04] 조치 방법

Ubuntu 역시 `rsyslog`를 사용하지만, 상세 설정이 `/etc/rsyslog.d/` 디렉토리에 분산되어 있을 수 있습니다.

Step 1) 로그 정책 설정 수정

1. 설정 파일 열기: `sudo vi /etc/rsyslog.d/50-default.conf` (또는 `/etc/rsyslog.conf`)

2. 보안 권고 사항 반영: Plaintext

```
# 인증 관련 로그
auth,authpriv.* /var/log/auth.log

# 전체 시스템 로그
*.*;auth,authpriv.none -/var/log/syslog

# 메일 및 크론 로그
cron.* /var/log/cron.log
mail.* -/var/log/mail.log
```

Step 2) 서비스 재시작

Bash

```
sudo systemctl restart rsyslog
```

⚠ 조치 시 주의사항 (공통)

- **로그 파일 권한 점검:** 생성된 로그 파일은 root 계정만 읽을 수 있도록 권한을 관리해야 합니다. (보통 600 또는 640 권한 권장)
- **저장 공간 관리:** 로그 양이 많아지면 디스크 풀(Full) 장애가 발생할 수 있습니다. 반드시 `logrotate` 도구를 함께 사용하여 로그를 주기적으로 압축 및 분할 관리하십시오.
- **원격 로그 서버:** 로컬 로그는 공격자에 의해 삭제될 위험이 있으므로, 중요한 시스템은 별도의 **원격 로그 서버(Syslog Server)**로 로그를 실시간 전송하도록 설정하는 것이 좋습니다.
- **시간 동기화:** 로그의 타임스탬프가 정확해야 증거 효력이 있습니다. `Chrony` 또는 `NTP` 를 통해 시스템 시간을 항상 표준시와 동기화하십시오.